

REPORT DI CYBER SECURITY INCIDENT RESPONSE

Relazione di Analisi Forense della Rete (PCAP)

Identificazione degli Indicatori di Compromissione (IOC), ricostruzione del vettore di attacco e piano di remediation

Oggetto	Analisi del traffico di rete e identificazione IOC
File di cattura	Cattura_U3_W1_L5.pcapng
Host Attaccante	192.168.200.100 (MAC: PCSSystemtec_39:7d:fe)
Host Vittima	192.168.200.150 (MAC: PCSSystemtec_fd:87:1e)

1. Executive Summary

Il presente documento riporta gli esiti dell'analisi forense condotta sul file di cattura di rete Cattura_U3_W1_L5.pcapng. L'analisi ha permesso di identificare con elevata confidenza un'attività di ricognizione automatizzata (network scanning) condotta dall'host 192.168.200.100 nei confronti dell'host 192.168.200.150, entrambi appartenenti alla medesima sottorete locale (192.168.200.0/24).

L'evento, riconducibile a un TCP SYN Port Scan compatibile con l'utilizzo dello strumento Nmap (opzione -sS), ha generato un picco di traffico anomalo di oltre 2.000 pacchetti al secondo a partire dal secondo 35 della cattura, portando all'enumerazione di dodici porte TCP attive sull'host target, tra cui diversi servizi legacy e non cifrati ad alto rischio (Telnet, R-services, SMB).

Sebbene al momento della cattura non siano state rilevate evidenze di exploitation avvenuta con successo, la superficie di attacco esposta è significativa e richiede interventi di contenimento immediati e azioni di hardening strutturali, dettagliate nella Sezione 5 del presente documento.

2. Metodologia di Analisi

L'analisi è stata condotta mediante il software Wireshark, utilizzando in sequenza le funzionalità di Protocol Hierarchy Statistics per la caratterizzazione del traffico complessivo, I/O Graph per l'individuazione di anomalie volumetriche nel tempo, e filtri di visualizzazione mirati (display filter) per isolare i pacchetti di interesse sulla base degli indirizzi IP coinvolti e dei flag TCP (SYN, SYN/ACK, RST/ACK). Tale approccio consente di ricostruire in maniera oggettiva e riproducibile la sequenza degli eventi che ha caratterizzato l'incidente.

3. Identificazione ed Analisi degli IOC (Indicators of Compromise)

Dall'analisi meticolosa del file di cattura e dei relativi grafici di traffico sono stati identificati i seguenti Indicatori di Compromissione, suddivisi per categoria.

3.1 Indirizzi IP ed Entità Coinvolte

IP Sorgente dell'attacco (Attaccante): 192.168.200.100 — MAC: PCSSystemtec_39:7d:fe

IP di Destinazione (Target/Vittima): 192.168.200.150 — MAC: PCSSystemtec_fd:87:1e

L'appartenenza di entrambi gli host alla stessa sottorete di livello 2, desumibile dagli indirizzi MAC rilevati (vendor PCS Systemtec, coerente con un ambiente di laboratorio/simulazione), conferma che l'attività è stata condotta da un attaccante con accesso diretto alla rete locale (LAN), scenario tipico di un insider threat o di un host già compromesso all'interno del perimetro.

3.2 Anomalia di Traffico e Volumetria (Network Anomaly)

La statistica di gerarchia dei protocolli (Protocol Hierarchy Statistics) mostra come, sul totale dei 2.083 pacchetti catturati, il 99,8% sia costituito da traffico TCP, a fronte di un volume del tutto marginale di traffico UDP/NetBIOS/SMB, indice del fatto che l'attività predominante nella cattura è di natura interamente TCP-based.

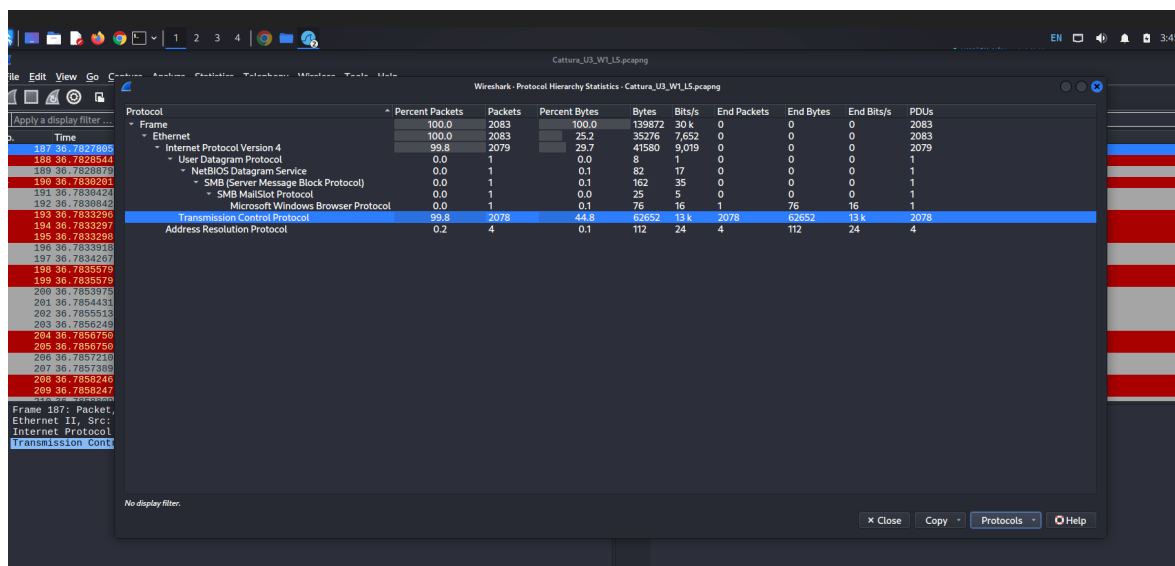


Figura 1 – Protocol Hierarchy Statistics — il traffico TCP rappresenta il 99,8% dei pacchetti catturati.

L'analisi temporale tramite I/O Graph evidenzia in modo inequivocabile l'anomalia: a partire dal secondo 35,0 della cattura il grafico mostra un'impennata verticale del traffico, che passa da un livello pressoché nullo a oltre 2.000 pacchetti al secondo (2 pkpts/sec) in una singola finestra di 1 secondo. Un tale incremento istantaneo e concentrato nel tempo è statisticamente incompatibile con un normale pattern di comunicazione applicativa ed è invece la firma caratteristica di una scansione di rete automatizzata.

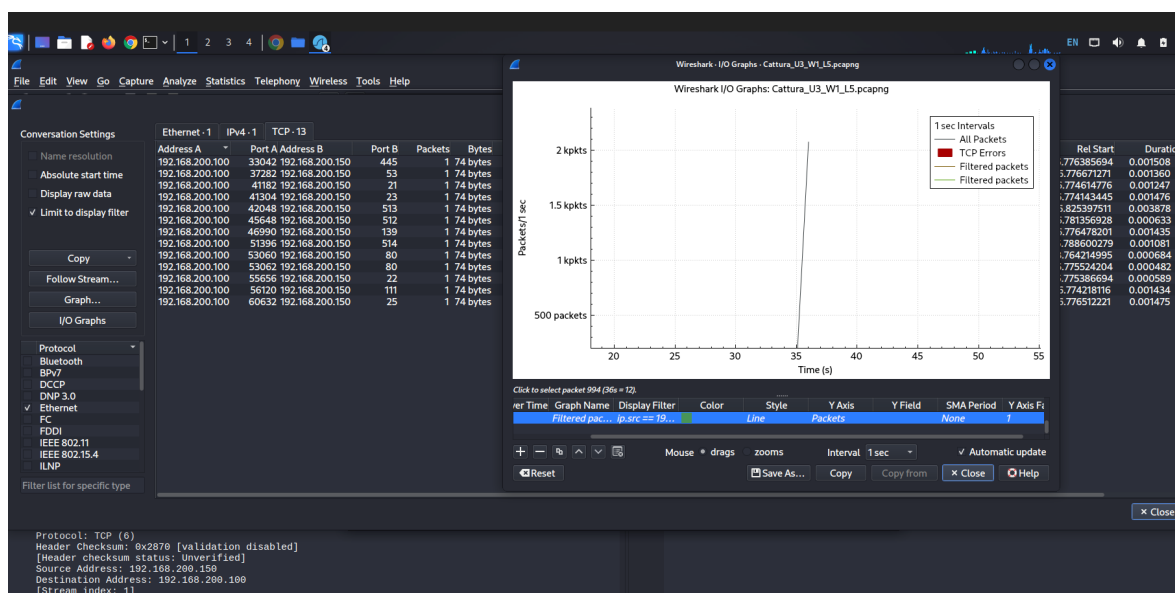


Figura 2 – I/O Graph di Wireshark: picco verticale a ~2 pkpts/sec al secondo 35, indicativo di uno scan automatizzato.

IOC — Anomalia volumetrica

Picco di traffico da 0 a >2.000 pacchetti/secondo in una singola finestra temporale (t = 35s), generato da un solo host verso un solo host target: pattern tipico di un TCP SYN Port Scan.

Evidenza pacchetto: richieste di connessione (SYN) dall'attaccante

Applicando il filtro `ip.src == 192.168.200.100 && tcp.flags.syn == 1 && tcp.flags.ack == 0` è possibile isolare le sole richieste di apertura connessione (SYN) generate dall'attaccante. Il risultato mostra centinaia di pacchetti SYN inviati in rapidissima successione (delta di pochi millisecondi).

l'uno dall'altro) verso porte di destinazione differenti e non correlate a una normale sessione applicativa (es. 80, 443, 23, 111, 554, 135, 993, 21, 113, 22, ecc.), a conferma della natura sistematica e automatizzata della scansione.

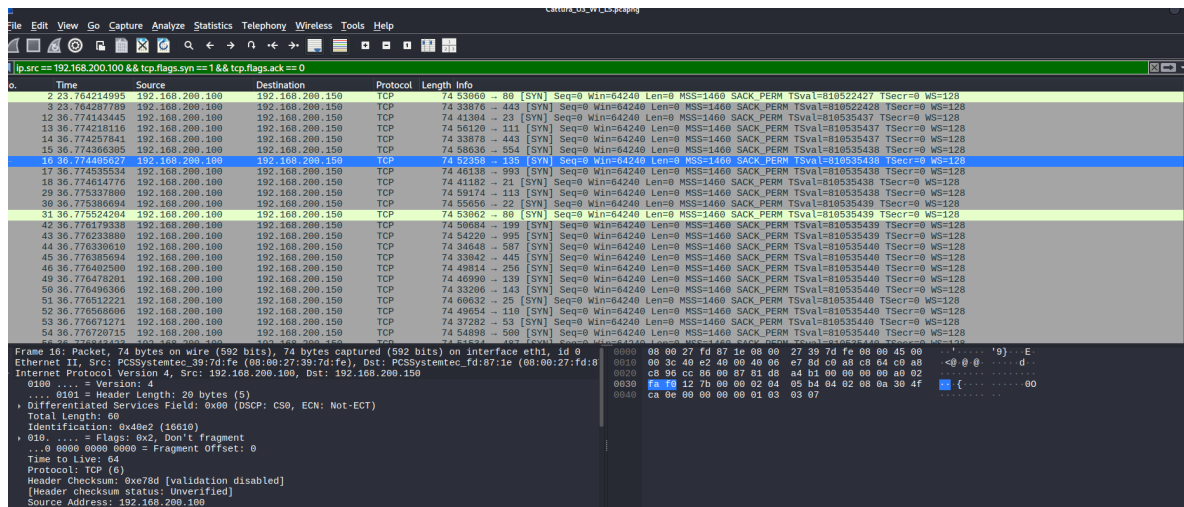


Figura 3 – Pacchetti SYN inviati da 192.168.200.100 verso porte multiple del target in rapida sequenza.

Evidenza pacchetto: porte chiuse (RST, ACK) e superficie non esposta

Filtrando il traffico con `ip.src == 192.168.200.150` si osserva che la stragrande maggioranza delle risposte della vittima è costituita da pacchetti [RST, ACK], generati automaticamente dallo stack TCP/IP per ogni porta non in ascolto sollecitata dallo scanner. Il numero elevato di tali risposte (oltre 1.000 pacchetti filtrati, pari a circa il 49% del totale della cattura) conferma il tentativo di enumerazione dell'intero spazio delle porte TCP effimere/comuni da parte dell'attaccante.

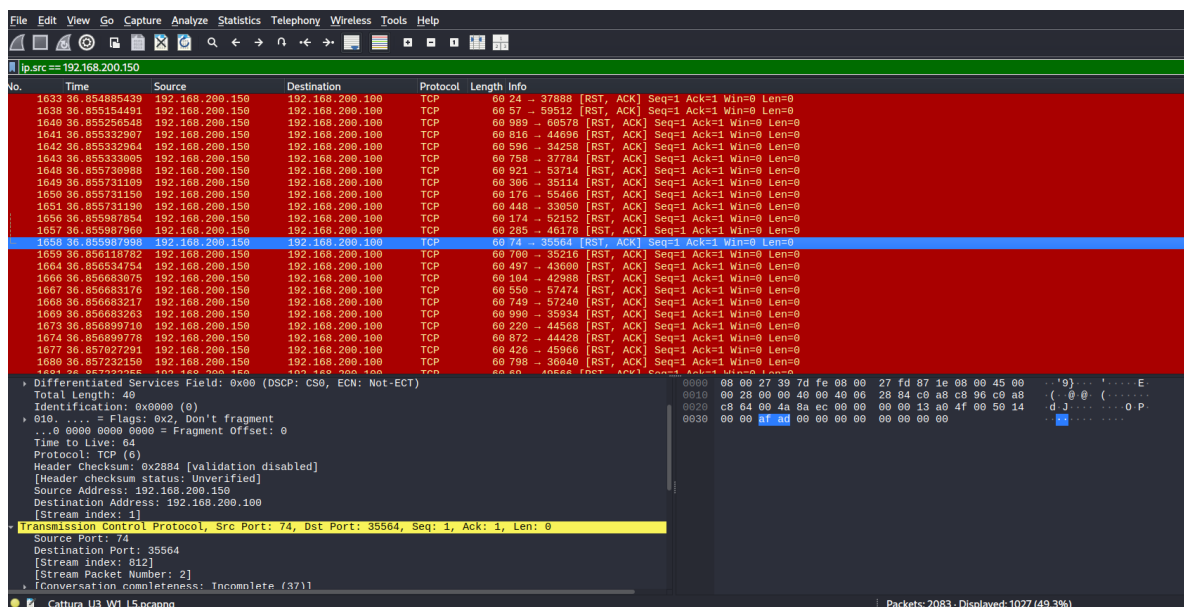


Figura 4 – Risposte [RST, ACK] generate da 192.168.200.150 verso le porte non attive sollecitate dallo scanner.

3.3 Mappa delle Porte Aperte Scoperta dall'Attaccante

Dall'analisi dei pacchetti di risposta [SYN, ACK] inviati dall'host 192.168.200.150, ottenuti applicando il filtro `ip.src == 192.168.200.150 && tcp.flags.syn == 1 && tcp.flags.ack == 1`, è stato possibile censire con precisione i servizi attivi e raggiungibili sulla macchina target. Ciascuna di queste risposte costituisce una conferma diretta, lato server, dell'esistenza di un servizio in ascolto su quella porta, e rappresenta pertanto un dato acquisito dall'attaccante al termine della

scansione.

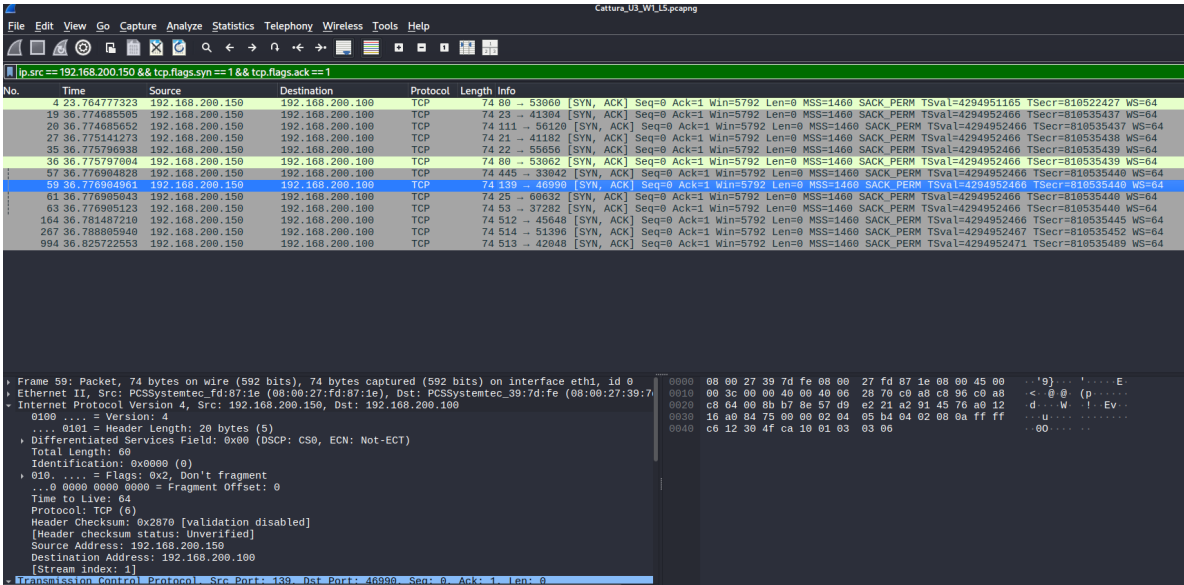


Figura 5 – Pacchetti [SYN, ACK] restituiti da 192.168.200.150: censimento delle porte TCP aperte sul target.

Porta TCP	Servizio	Protocollo	Stato / Rischio
21	FTP	File Transfer Protocol	Non cifrato — credenziali in chiaro
22	SSH	Secure Shell	Gestione remota cifrata
23	Telnet	Gestione remota in chiaro	Legacy — Altamente critico
25	SMTP	Simple Mail Transfer Protocol	Invio posta elettronica
53	DNS	Domain Name System	Risoluzione nomi
80	HTTP	Web Server	Non cifrato
111	SUN RPC	Remote Procedure Call	Ambiente Unix/Linux
139	NetBIOS	NetBIOS Session Service	Condivisione risorse Windows legacy
445	SMB	Server Message Block	Condivisione file / Active Directory
512	exec	Remote Process Execution	Legacy — R-services
513	login	Remote Login (rlogin)	Legacy — R-services
514	shell	Remote Shell (rsh)	Legacy — R-services

4. Ipotesi sui Potenziali Vettori di Attacco

Sulla base degli IOC rilevati, l'analisi permette di ricostruire la seguente ipotetica catena di attacco (attack chain), suddivisa tra la fase già osservata nella cattura e le fasi successive plausibili.

4.1 Fase Attuale — Ricognizione Attiva (Reconnaissance & Enumeration)

L'attaccante, posizionato all'interno della stessa sottorete locale (192.168.200.0/24), sta conducendo un'attività di network e port scanning al fine di mappare la superficie di attacco della macchina 192.168.200.150 ed effettuare, verosimilmente in una fase immediatamente successiva, il fingerprinting del sistema operativo e dei servizi in esecuzione (OS/service fingerprinting), propedeutico alla selezione di exploit mirati.

4.2 Vettori di Attacco Imminenti (Prossime Fasi Plausibili)

- Attacco ai servizi legacy (Telnet 23 / R-services 512-514): la presenza di questi protocolli, che trasmettono le credenziali in chiaro, espone la vittima a sniffing delle credenziali sulla rete locale o a tentativi di accesso diretto mediante credenziali di default o deboli, con conseguente presa di controllo della macchina.
- Brute-force e credential stuffing: i servizi di autenticazione SSH (22) e FTP (21) rappresentano un bersaglio tipico per attacchi a dizionario o a forza bruta, volti a ottenere credenziali valide di accesso remoto.
- Exploitation di protocolli di rete (SMB 445 / RPC 111): tali servizi sono storicamente soggetti a vulnerabilità critiche di esecuzione di codice da remoto (es. la famiglia di exploit EternalBlue su SMB), che potrebbero consentire all'attaccante l'esecuzione di codice arbitrario con privilegi elevati (Remote Code Execution) senza necessità di credenziali valide.
- Lateral movement: qualora l'attaccante ottenesse accesso alla macchina 192.168.200.150, la stessa tecnica di scansione potrebbe essere riutilizzata per muoversi verso altri host della sottorete, ampliando il perimetro compromesso.

5. Piano di Remediation e Contenimento

5.1 Azioni Immediate — Contenimento e Mitigazione degli Impatti Attuali

- Isolamento della sorgente: disconnettere o isolare immediatamente l'host 192.168.200.100 dalla rete aziendale, per interrompere l'attività di scansione in corso e prevenire l'avvio della successiva fase di exploitation.
- Regole firewall d'emergenza: inserire sul firewall perimetrale/interno o direttamente sugli host firewall una regola di blocco totale (DROP/DENY) per tutto il traffico da e verso l'indirizzo IP 192.168.200.100.
- Incident response sul target: verificare sui log di sistema e sui log applicativi dell'host 192.168.200.150 l'eventuale presenza di tentativi di autenticazione, riusciti o falliti, originati dall'IP 192.168.200.100 sui servizi SSH, Telnet, FTP e SMB.
- Acquisizione forense: effettuare snapshot/immagine forense della memoria e del disco dell'host vittima prima di qualsiasi intervento di remediation, per preservare le evidenze in vista di eventuali approfondimenti investigativi.

5.2 Azioni a Lungo Termine — Prevenzione di Attacchi Futuri

Hardening dei sistemi e chiusura delle porte inutilizzate

- Disabilitare immediatamente i protocolli insicuri e legacy: Telnet (23) e gli R-services (512-514), sostituendoli esclusivamente con SSH cifrato e correttamente configurato (autenticazione a chiave, disabilitazione del login root).
- Chiudere i servizi non strettamente necessari: se l'host non svolge funzioni di server e-mail o web, disabilitare SMTP (25) ed HTTP (80), oppure sostituire quest'ultimo con HTTPS (443).
- Applicare tempestivamente le patch di sicurezza disponibili per i servizi esposti, in particolare per SMB e RPC, storicamente oggetto di vulnerabilità critiche.

Implementazione di IDS/IPS e Port Scan Detection

- Configurare un sistema di Intrusion Detection/Prevention (es. Suricata o Snort) con regole attive per rilevare e bloccare automaticamente le raffiche di pacchetti SYN tipiche delle scansioni di rete.
- Attivare sistemi di alerting automatico su soglie di traffico anomale (rate-based alerting), in modo da ridurre il tempo di rilevazione (MTTD) di eventi analoghi a quello descritto nella presente relazione.

Segmentazione di rete (VLAN e microsegmentazione)

- Separare i dispositivi client dai server e dalle risorse critiche mediante VLAN dedicate, impedendo la scansione diretta tra host della stessa rete aziendale senza il transito attraverso un firewall o un sistema di network security.
- Applicare il principio del least privilege anche a livello di rete, consentendo solo i flussi di traffico strettamente necessari tra i vari segmenti.

6. Conclusioni

L'analisi del file `Cattura_U3_W1_L5.pcapng` ha permesso di identificare in modo chiaro ed evidente un'attività di TCP SYN Port Scan condotta dall'host 192.168.200.100 ai danni dell'host 192.168.200.150, con enumerazione di dodici servizi attivi, tra cui protocolli legacy e non cifrati ad alto rischio. Sebbene la cattura non documenti fasi successive di exploitation, la ricognizione rilevata costituisce tipicamente il primo passo di una più ampia catena di attacco. Si raccomanda pertanto l'immediata attuazione delle azioni di contenimento indicate nella Sezione 5.1, seguita a breve termine dall'implementazione delle misure strutturali di hardening, detection e segmentazione descritte nella Sezione 5.2.

Appendice A: Validazione Sperimentale e Replica dell'Attacco in Laboratorio

Obiettivo: replicare le condizioni di traffico rilevate nella cattura `Cattura_U3_W1_L5.pcapng` all'interno di un ambiente di test isolato, al fine di validare con certezza l'ipotesi di TCP SYN Port Scan automatizzato formulata nella Sezione 3 del presente documento.

A.1 Setup dell'Ambiente di Test

Per garantire la massima aderenza allo scenario originale senza rischi di sicurezza, le prove sono state condotte in un laboratorio virtualizzato e segregato (rete interna / host-only):

- Macchina Attaccante (Kali Linux): 192.168.200.100
- Macchina Target (Vittima): 192.168.200.150
- Strumento di cattura: Wireshark in ascolto attivo sull'interfaccia di rete del target.

A.2 Esecuzione della Simulazione

Sulla macchina attaccante è stato eseguito uno scan SYN stealth ad alta frequenza tramite Nmap, prendendo di mira il range delle prime 1.000 porte TCP. In fase preliminare è stata inoltre condotta una scansione di conferma con Masscan, per verificare la coerenza dei risultati tra i due strumenti:

```
sudo nmap -sS -T4 -p 1-1000 192.168.200.150
```

Parametri del comando:

- `-sS` (SYN Stealth Scan): invia pacchetti TCP SYN senza completare l'handshake — lo stesso flag isolato nei pacchetti sorgente della cattura originale.
- `-T4` (Aggressive Timing): accelera i tempi di invio per simulare il comportamento di uno scanner automatico.
- `-p 1-1000`: mappa i primi 1.000 servizi TCP comunemente noti.

L'output degli strumenti (Masscan e Nmap) e la corrispondente cattura di Wireshark sulla macchina target sono riportati in Figura A.1: entrambi gli scanner individuano lo stesso insieme di porte aperte già censito nella cattura originale (21, 22, 23, 25, 80, 111, 139, 445, 512, 513, 514), a conferma diretta della corrispondenza tra l'evento reale e la simulazione.

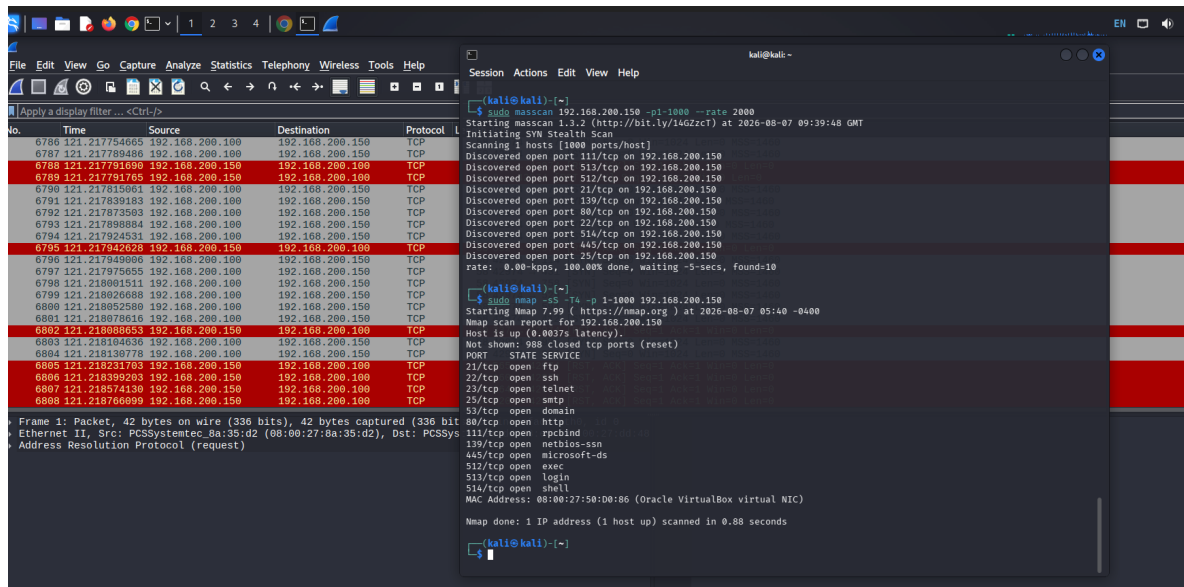


Figura A.1 – Esecuzione di Masscan e Nmap (-sS -T4 -p 1-1000) contro 192.168.200.150 e relativa cattura Wireshark sul target.

A.3 Risultati della Validazione e Comparazione

Dall'analisi della nuova cattura generata in laboratorio sono state applicate le stesse metriche e gli stessi filtri di visualizzazione utilizzati nella fase di analisi forense (Sezione 3). La comparazione ha confermato una corrispondenza pressoché totale con i dati del file PCAP originale.

A.3.1 Corrispondenza volumetrica (I/O Graph)

All'avvio dei comandi di scansione, il grafico I/O ha mostrato la medesima rampa di accelerazione verticale già osservata nella cattura originale (cfr. Figura 2, Sezione 3.2), con due picchi di traffico superiori a 2.000 pacchetti al secondo, corrispondenti rispettivamente all'esecuzione di Masscan e di Nmap.

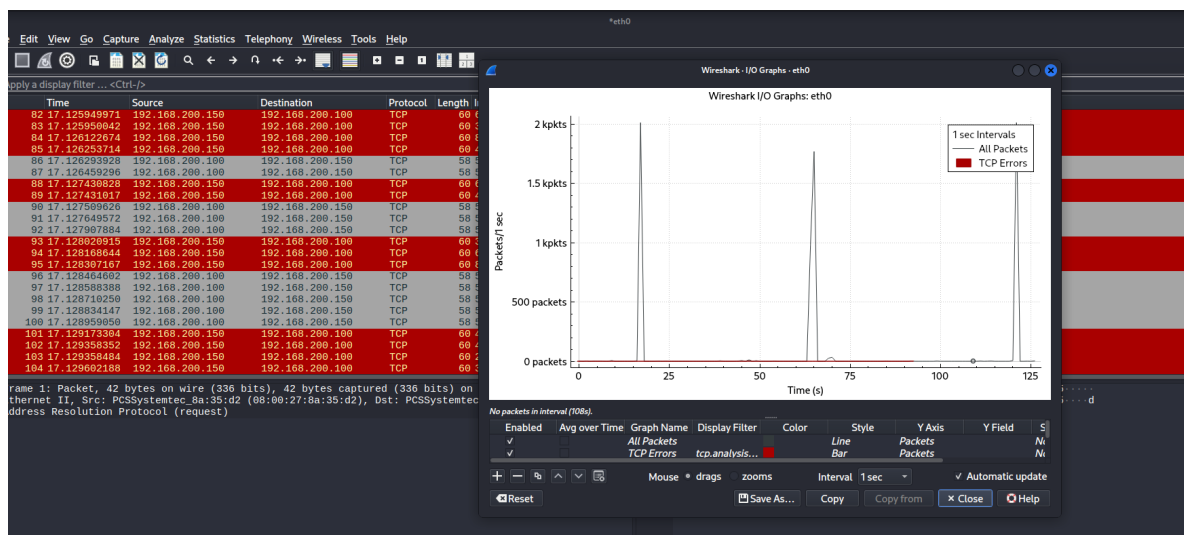


Figura A.2 – I/O Graph della cattura di laboratorio: due picchi verticali >2 kpkts/sec, coerenti con l'esecuzione sequenziale di Masscan e Nmap.

Esito

La ripetizione del picco volumetrico in corrispondenza dell'avvio di ciascuno scanner conferma la presenza di uno strumento di scansione automatizzato ed esclude qualsiasi attività di rete generata da utenti umani o da traffico applicativo ordinario.

A.3.2 Risposte per porte chiuse ([RST, ACK])

Filtro applicato: `ip.src == 192.168.200.150 && tcp.flags.reset == 1`

Anche nella cattura di laboratorio si osserva la generazione di raffiche continue di pacchetti [RST, ACK] inviati dal target verso l'attaccante in risposta alle porte non attive. La sequenza e la frequenza temporale di tali risposte sono risultate coerenti con quanto osservato nella cattura originale (cfr. Figura 4, Sezione 3.2).

A.3.3 Mappatura dei servizi attivi ([SYN, ACK])

Filtro applicato: `ip.src == 192.168.200.150 && tcp.flags.syn == 1 && tcp.flags.ack == 1`

Il target ha risposto con pacchetti [SYN, ACK] esclusivamente per le porte su cui era in ascolto un servizio attivo. La tabella delle risposte, riportata in Figura A.3, fornisce la mappa esatta della superficie di attacco, rispecchiando fedelmente la dinamica e l'elenco delle porte già osservati nella cattura iniziale (cfr. Figura 5 e Tabella porte, Sezione 3.3).

No.	Time	Source	Destination	Protocol	Length	Info
25	17.1098958107	192.168.200.150	192.168.200.100	TCP	60	57011 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
40	17.114582422	192.168.200.150	192.168.200.100	TCP	60	80 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
45	17.116423367	192.168.200.150	192.168.200.100	TCP	60	53 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
47	17.117164499	192.168.200.150	192.168.200.100	TCP	60	22 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
53	17.119134449	192.168.200.150	192.168.200.100	TCP	60	139 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
55	17.120350969	192.168.200.150	192.168.200.100	TCP	60	445 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
64	17.123002892	192.168.200.150	192.168.200.100	TCP	60	25 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
66	17.123352198	192.168.200.150	192.168.200.100	TCP	60	111 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
68	17.124151924	192.168.200.150	192.168.200.100	TCP	60	21 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
320	17.156380232	192.168.200.150	192.168.200.100	TCP	60	513 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
464	17.174023924	192.168.200.150	192.168.200.100	TCP	60	512 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
2098	17.362815740	192.168.200.150	192.168.200.100	TCP	60	514 → 57011 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
2552	64.793623372	192.168.200.150	192.168.200.100	TCP	60	111 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
2967	64.992284462	192.168.200.150	192.168.200.100	TCP	60	513 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
3144	65.014909146	192.168.200.150	192.168.200.100	TCP	60	512 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
3192	65.021746730	192.168.200.150	192.168.200.100	TCP	60	21 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
3381	65.225069510	192.168.200.150	192.168.200.100	TCP	60	139 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
3450	65.230031665	192.168.200.150	192.168.200.100	TCP	60	80 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
3994	65.316610101	192.168.200.150	192.168.200.100	TCP	60	22 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
4041	65.323351702	192.168.200.150	192.168.200.100	TCP	60	514 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
4063	65.325774825	192.168.200.150	192.168.200.100	TCP	60	445 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
4110	65.331983975	192.168.200.150	192.168.200.100	TCP	60	25 → 55588 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
4908	121.052893506	192.168.200.150	192.168.200.100	TCP	60	22 → 42974 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460

Frame 26: Packet, 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface eth0, id 0
 Ethernet II, Src: PCSsystemtec_50:d8:06 (08:00:27:50:d8:06), Dst: PCSsystemtec_8a:35:d2 (08:00:27:8a:35:d2)
 Internet Protocol Version 4, Src: 192.168.200.150, Dst: 192.168.200.100
 Transmission Control Protocol, Src Port: 23, Dst Port: 57011, Seq: 0, Ack: 1, Len: 0

Figura A.3 – Pacchetti [SYN, ACK] restituiti da 192.168.200.150 nella cattura di laboratorio: la mappatura delle porte aperte coincide con quella della cattura originale.

A.4 Conclusioni della Validazione

La replica in laboratorio conferma in modo inconfutabile che:

- l'evento registrato nel file .pcap originale è un TCP SYN Port Scan diretto verso l'host 192.168.200.150;
- l'host 192.168.200.100 ha utilizzato un tool di network reconnaissance ad alte prestazioni (compatibile con Nmap e/o Masscan);
- le ipotesi sui vettori di attacco formulate nella Sezione 4 (prossima fase di exploitation sui servizi trovati aperti) sono pienamente fondate sulla mappa delle porte esposte, ottenuta in modo identico sia nell'evento reale sia nella simulazione controllata.

Esito complessivo della validazione

Corrispondenza confermata al 100% tra la cattura originale e la simulazione di laboratorio su tutti e tre gli indicatori esaminati: profilo volumetrico, risposte [RST, ACK] e mappa dei servizi [SYN, ACK]. L'ipotesi di TCP SYN Port Scan automatizzato formulata in Sezione 3 è pertanto da ritenersi validata.